

Incident Summary

1) Title Of the Incident

WAF: - Cross-Site Scripting (Ticket No: -CS-0210)

2) Incident Details

- **Receive Time:** - 12/28/2024 5:06
- **Source IP:** -
- **Destination IP:** -
- **Destination Port:** - 443
- **Site Name:** -
- **Threat Name:** - Cross-Site Scripting
- **Action Taken:** - Allowed
- **Severity:** - Medium
- **URL:** - /admin
- **Direction:** - Inbound

3) Description Of Incident

- On **December 28, 2024, at 05:06**, the Web Application Firewall (WAF) detected a potential **Cross-Site Scripting (XSS) attack attempt** targeting the internal web application hosted at
- The malicious request originated from the external IP address and was directed towards the internal server over **HTTPS (port 443)**. The attacker attempted to exploit the **/admin URL path**, which is a sensitive application endpoint.
- The WAF generated an alert and logged the request, categorizing the event as **Medium severity**. However, the action taken by the WAF was **Allowed**.

4) Investigation Summary

- **Source IP:**
 - Not part of the internal organization.
 - Reputation check on **AbuseIPDB**: Not reported as malicious.
 - **ISP**: Okpay Investment Company
 - **Usage Type**: Data Center / Web Hosting / Transit
 - **ASN**: Unknown

- **Domain Name:** web4net.org
- **Location:** Roosendaal, North Brabant, Netherlands
- **Destination IP:** ()
 - **Operating System:** RHEL 8
 - **Role:** Web Server (AWS Cloud)
 - **Business Criticality:** Low
 - **Department:** IT
 - **Owner:** Team (Head of IT –
 - **Commissioned:** 03/13/2023
 - **Decommission Date:** 08/31/2030
 - **Status:** Active

-

- **Splunk Findings**

- **Total Events Observed:** 1,734
 - **Firewall:** 725 (All Allowed)
 - **IPS:** 725 (All Allowed)
 - **WAF:** 215 Allowed, 69 Blocked
- **Focus on WAF Allowed Events (215 total):**
 - **Normal Events:** 213 (99.07%)
 - **Suspicious Events:**
 - **Cross-Site Scripting (XSS):** 1 event (0.465%)
 - **Directory Traversal:** 1 event (0.465%)

-

- **Key Event Details (XSS Attempt)**

- **Site Name:**
- **Target URL:** /admin
- **Response Code:** 401 (Unauthorized)
- **Matched String (Payload):**

Additional Suspicious Event – Directory Traversal Attempt

- **Splunk Query:**

index=main "45.227.255.2" sourcetype=waf_logs Action=Allowed Threat_Name="Directory Traversal"

Event Details:

- **Application Protocol:** HTTP/1.1
- **HTTP Method:** GET
- **Matched String (Payload):**

../../../../etc/passwd

- → Attempt to read the system password file (/etc/passwd) via directory traversal.
- **Response Code:** 403 (Forbidden)
- **Target URL:** /admin
- The attacker from attempted to perform a **directory traversal attack** on the /admin of
- The payload ../../../../etc/passwd is a **common malicious pattern** used to try and access sensitive system files outside the web root directory.
- The WAF logged the request and marked it as **Directory Traversal**, but the action was **Allowed**, which means the request reached the application server.
- The **403 Forbidden response** indicates that the web application/server rejected the request, preventing the attacker from retrieving sensitive files.

5)Action Taken

- **Source IP (45.227.255.2)** added to the **firewall blocklist** to prevent further malicious activity.
- Raised a request with the Security engineering team **to update signatures and enforce stricter blocking rules for XSS and Directory Traversal patterns.**